Name: Harshal Navarkar
PRN:2124UCSM1015

IAM & Least Privilege Enforcement

Unit 2 Cloud Security Assignment Report

1. Objective

This project implements a rigorous AWS Identity and Access Management (IAM) structure following the Principle of Least Privilege. It creates three distinct IAM groups (Admins, Developers, Auditors) each with a custom, scoped policy; enforces Multi-Factor Authentication (MFA) for the Admins group; and provisions a custom IAM Role that allows an EC2 instance to access S3 securely without any hardcoded credentials.

2. Architecture Summary

- Admins — broad operational access (EC2, S3, IAM group/role management, CloudWatch/Logs), explicitly denied billing and AWS Organizations actions so even the admin tier is not root-equivalent.
- Developers — can run/stop/terminate EC2 instances and read/write only the project's S3 bucket; IAM actions are explicitly denied.
- Auditors — strict read-only access (Get*/List*/Describe*) across IAM, S3, EC2, CloudTrail and Config for compliance review, with no write permissions anywhere.
- MFA Enforcement — an additional policy attached to the Admins group denies nearly all actions unless the caller has authenticated with MFA, while still allowing users to enrol and manage their own MFA device.
- EC2 → S3 Role — a custom IAM Role (EC2-S3-Access-Role) with an instance profile lets an EC2 instance assume temporary credentials scoped to one S3 bucket only, eliminating the need for hardcoded access keys.

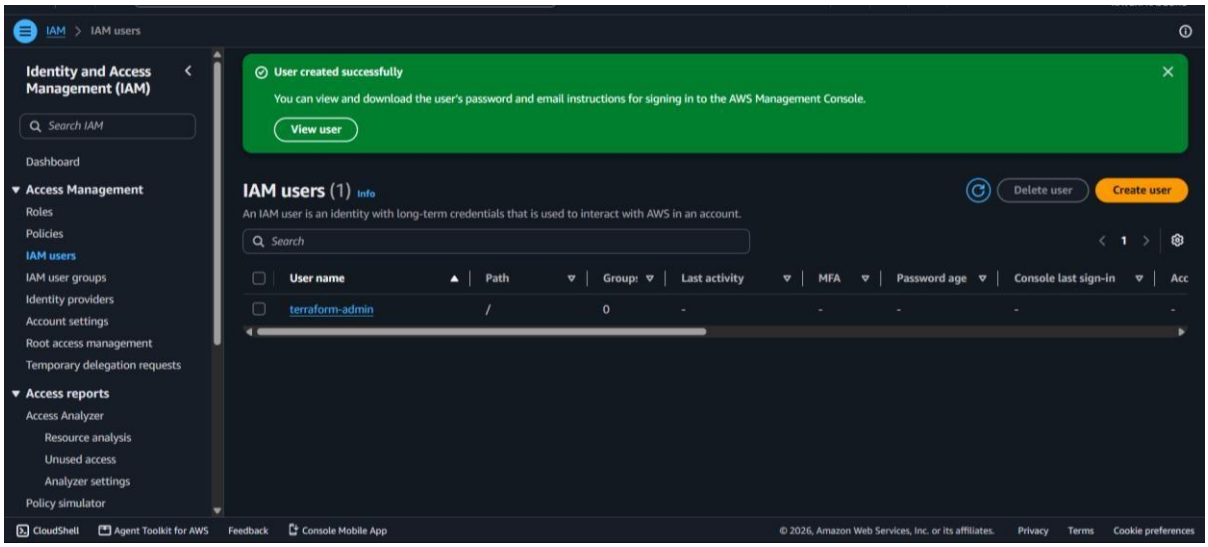
3. IAM Policy Matrix

Group	Key Permissions	Explicit Restrictions
Admins	EC2:*, S3:*, IAM group/role mgmt, CloudWatch:*, Logs:*	Deny billing, Organizations, account actions; MFA required for all actions
Developers	EC2 run/start/stop/terminate, S3 Get/Put/List on app bucket only	Deny all IAM:* actions
Auditors	IAM/S3/EC2 Get*/List*/Describe*, CloudTrail, Config read access	No write, create, or delete actions anywhere

4. Terraform Deployment Evidence

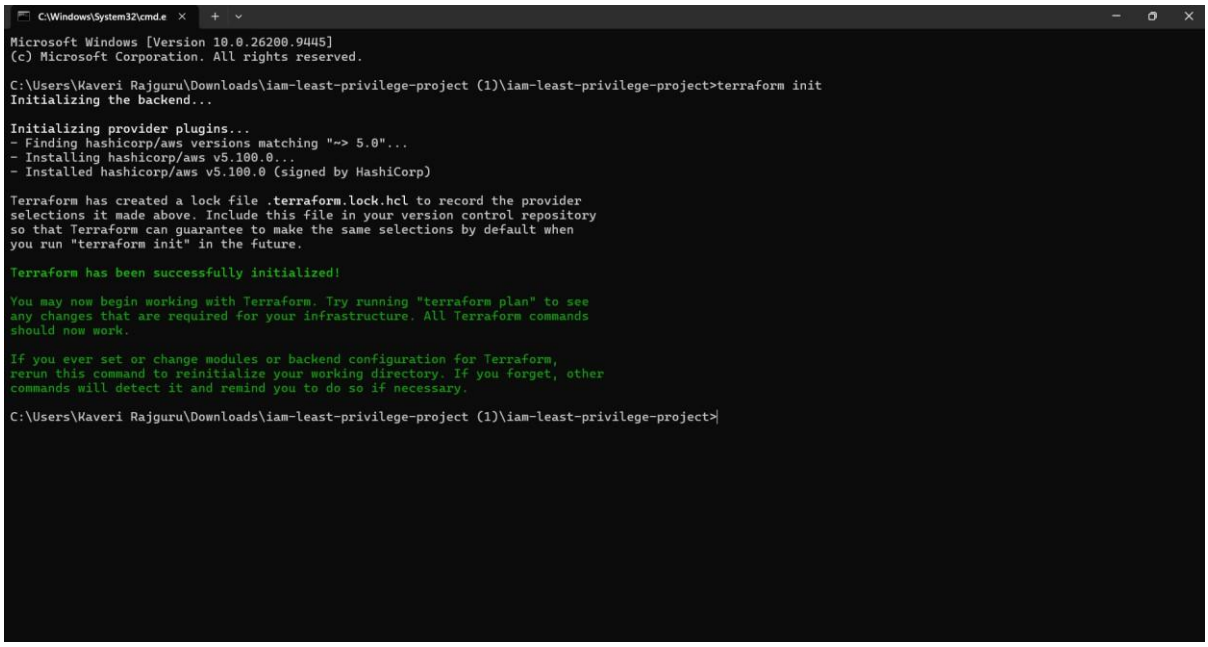
The infrastructure above was defined entirely in Terraform (HCL) and deployed to a real AWS account. The following screenshots document each stage of deployment, from admin-user setup through final verification in the AWS Console.

Screenshot 1 — IAM Admin User Created



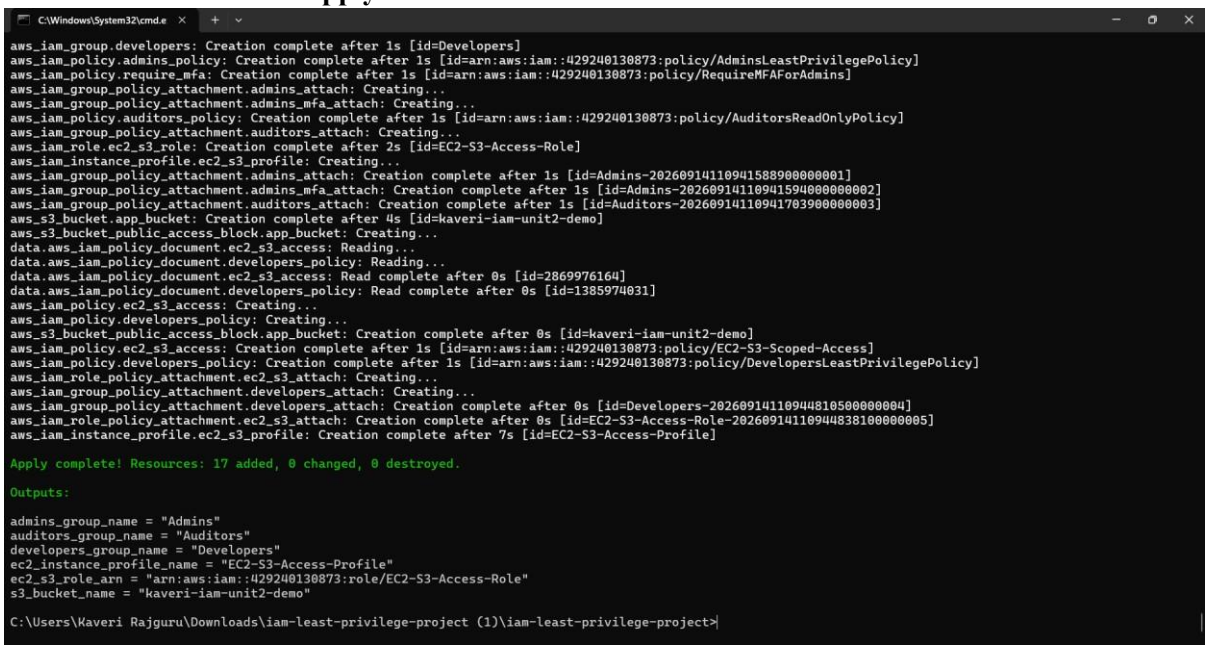
A dedicated IAM user (terraform-admin) with AdministratorAccess was created instead of using the AWS root account for daily operations, following AWS security best practice.

Screenshot 2 — terraform init



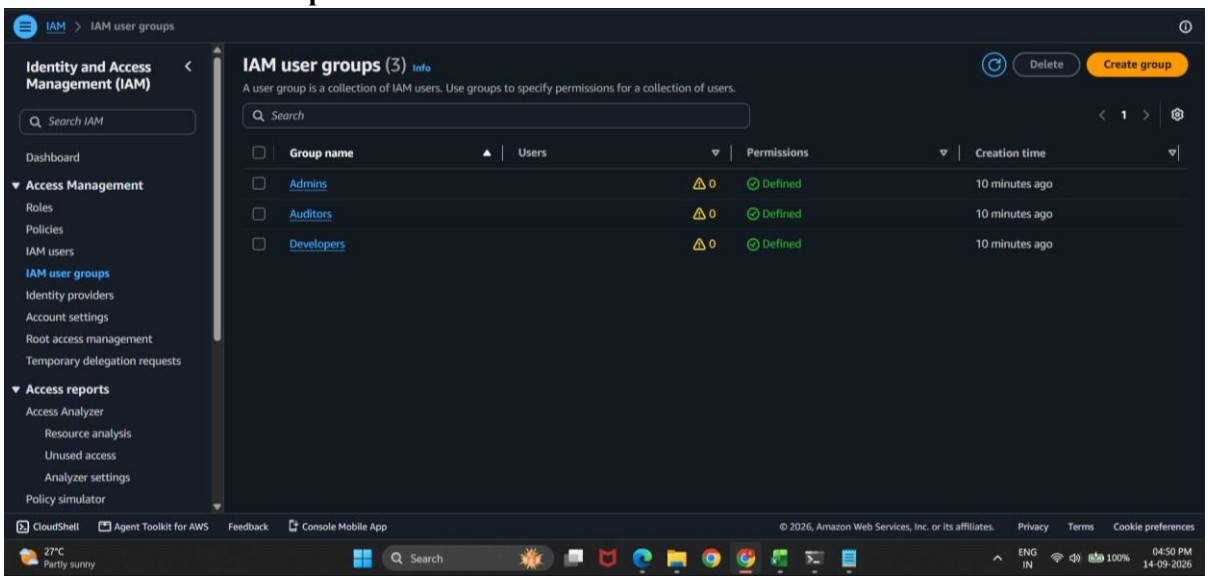
Terraform successfully initialized the working directory and downloaded the AWS provider (hashicorp/aws v5.100.0).

Screenshot 3 — terraform apply



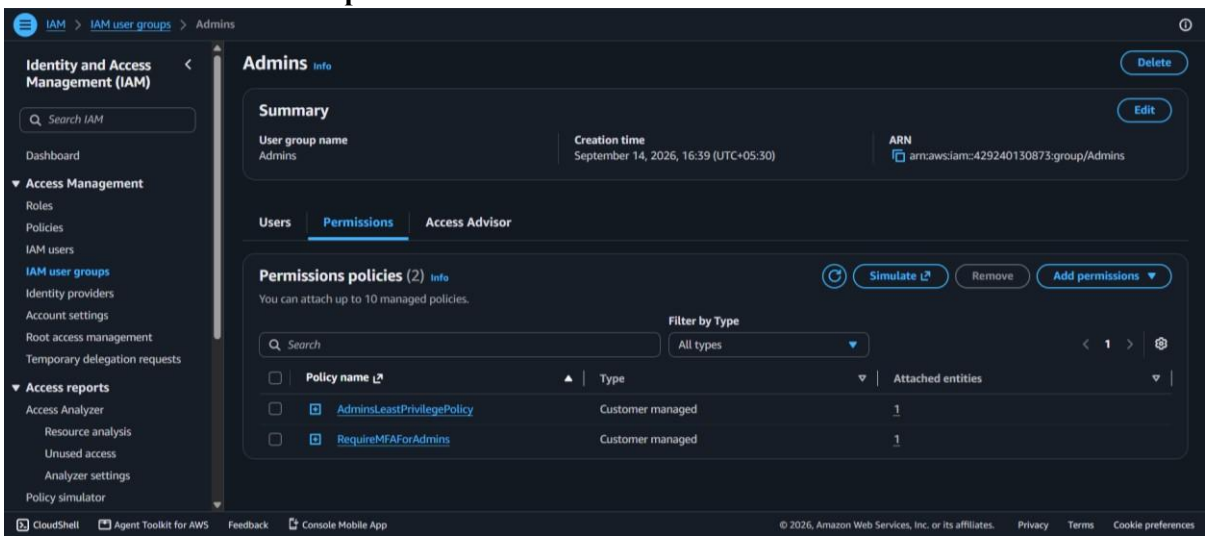
Terraform applied the configuration and created all 17 planned resources (IAM groups, policies, role, instance profile, and S3 bucket) with zero errors.

Screenshot 4 — IAM Groups Created



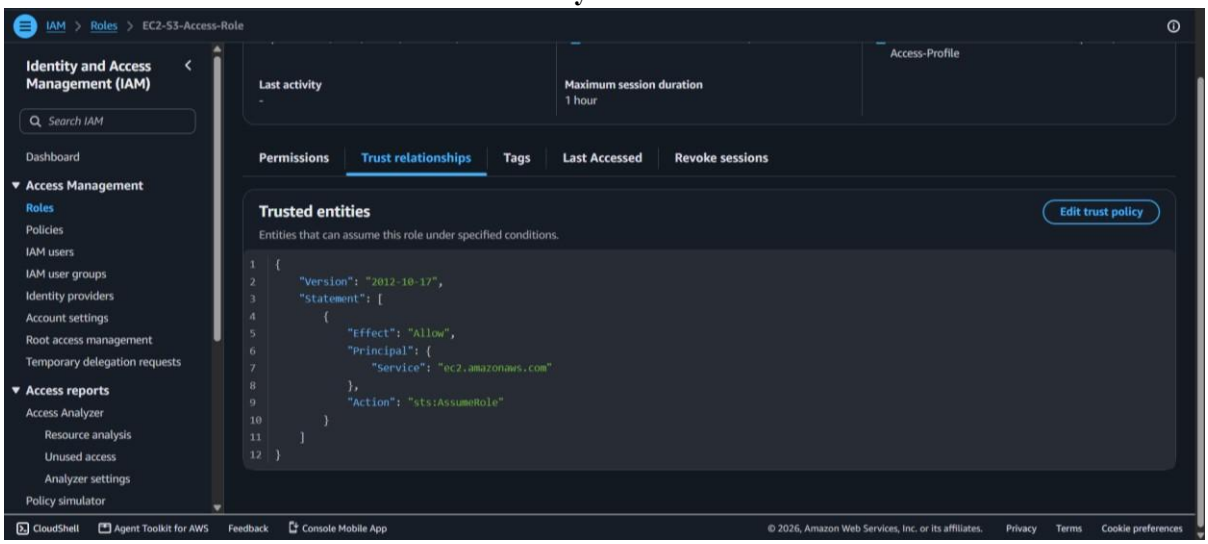
The AWS Console confirms all three IAM groups — Admins, Auditors, and Developers — were created, each with permissions defined.

Screenshot 5 — Admins Group MFA Enforcement



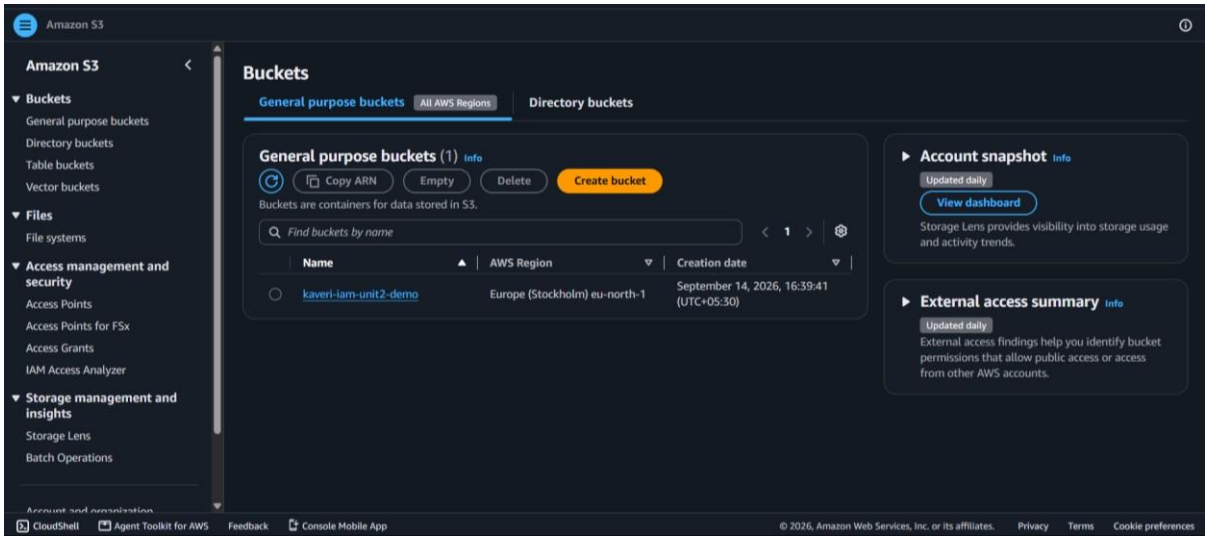
The Admins group has two policies attached: AdminsLeastPrivilegePolicy (scoped admin permissions) and RequireMFAForAdmins (denies actions unless MFA is present).

Screenshot 6 — EC2-S3-Access-Role Trust Policy



The custom IAM role's trust relationship allows only the EC2 service (ec2.amazonaws.com) to assume it via sts:AssumeRole, enabling credential-free access from EC2 instances.

Screenshot 7 — S3 Bucket Created



The application S3 bucket (kaveri-iam-unit2-demo) was provisioned in the eu-north-1 (Stockholm) region and is the target of the scoped Developer and EC2-role S3 permissions.

5. Source Code Repository

The complete Terraform source code, README documentation, and all screenshots have been published to GitHub:

https://github.com/kaverii18/iam-least-privilege

6. Conclusion

This project demonstrates a working, least-privilege IAM structure enforced through infrastructure-as-code. Each role's permissions are scoped to the minimum required for its function, administrative access is gated behind MFA, and EC2-to-S3 communication is handled through a temporary, role-assumed credential model rather than static access keys — meeting all requirements of the Unit 2 assignment.